

Clase 031 — Nmap: detección de servicios y fingerprinting de OS

Parte: **1 — Redes y seguridad de redes** · Fuente: *Nmap Network Scanning, G. Lyon* 🕒 Duración estimada: **100 min** · Nivel: **Intermedio**

🎯 Objetivo

Ir más allá de "puerto abierto" para saber **qué** servicio corre, en qué **versión** y sobre qué **sistema operativo**. El alumno aprenderá la detección de versiones (`-sV`), el fingerprinting de OS (`-O`), su relación con las vulnerabilidades conocidas y cómo interpretar la confianza de cada resultado.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Ejecutar** detección de versión de servicios y ajustar su intensidad.
2. **Realizar** fingerprinting de sistema operativo e interpretar el porcentaje de acierto.
3. **Leer** los campos de servicio (producto, versión, extrainfo, CPE).
4. **Relacionar** una versión detectada con vulnerabilidades conocidas (CVE) de forma responsable.
5. **Combinar** `-sV` , `-O` y scripts en un escaneo integral (`-A`).
6. **Reconocer** las limitaciones y falsos positivos del fingerprinting.

📖 Temas

#	Tema	Por qué importa
1	Detección de versión (<code>-sV</code>)	Convierte puertos en servicios concretos
2	Intensidad de sondeo (<code>--version-intensity</code>)	Precisión vs. ruido
3	nmap-service-probes y CPE	Cómo Nmap identifica y cataloga
4	OS fingerprinting (<code>-O</code>)	Adaptar tácticas al sistema
5	Fiabilidad y <code>--osscan-guess</code>	Interpretar la confianza
6	Escaneo agresivo (<code>-A</code>)	Todo en una pasada
7	De versión a vulnerabilidad (CVE/CPE)	Priorizar hallazgos

📖 Definiciones y características

- **Detección de versión (`-sV`)**: Nmap envía sondas específicas y compara las respuestas con la base `nmap-service-probes` para identificar producto y versión exacta.
- **CPE (Common Platform Enumeration)**: identificador estandarizado (`cpe:/a:apache:http_server:2.4.41`) que Nmap emite y que enlaza con bases de vulnerabilidades.

- **OS fingerprinting (-O)**: analiza detalles de la pila TCP/IP (ISN, opciones, tamaño de ventana, TTL) para inferir el sistema operativo.
- **Intensidad de versión (0-9)**: controla cuántas sondas se lanzan; mayor intensidad = más precisión y más ruido.
- **Fiabilidad de OS**: porcentaje que expresa cuán segura es la coincidencia; por debajo de cierto umbral Nmap muestra varias conjeturas.

Herramientas y preparación

- **Nmap 7.x** con privilegios (el fingerprinting de OS requiere raw sockets).
- Objetivos variados en el laboratorio: un Linux con SSH/HTTP, un Windows, un servicio en versión antigua (contenedor deliberadamente desactualizado, aislado).
- Opcional: `searchsploit` / base local de CVE para correlacionar versiones.

 **Nota ética**: identificar versiones para localizar vulnerabilidades es legítimo solo con autorización. No explotes nada fuera de tu laboratorio. Correlacionar CVEs es análisis; explotarlos sin permiso es un delito.

Laboratorio guiado

1. Detección de versión básica:

```
bash sudo nmap -sV 192.168.56.101
```

2. Aumenta intensidad para servicios difíciles:

```
bash sudo nmap -sV --version-intensity 9 192.168.56.101
```

3. Detección de OS:

```
bash sudo nmap -O 192.168.56.101
```

4. Fuerza conjeturas cuando no hay coincidencia exacta:

```
bash sudo nmap -O --osscan-guess 192.168.56.101
```

5. Escaneo agresivo (versión + OS + scripts por defecto + traceroute):

```
bash sudo nmap -A 192.168.56.101
```

6. Limita a puertos abiertos conocidos para ir más rápido:

```
bash sudo nmap -sV -p 22,80,443 192.168.56.101
```

7. Extrae los CPE de la salida XML:

```
bash sudo nmap -sV -oX serv.xml 192.168.56.101 grep -o 'cpe:[^<]*' serv.xml | sort -u
```

8. Correlaciona una versión con exploits conocidos (offline, informativo):

```
bash searchsploit "OpenSSH 7.2"
```

Ejercicios

1. Escanea un servicio y anota producto, versión y CPE exacto.
2. Compara `-O` con y sin `--osscan-guess` en un host difícil de identificar.
3. Ejecuta `-A` y clasifica qué información aporta cada sección de la salida.
4. Investiga por qué la detección de OS necesita al menos un puerto abierto y uno cerrado.
5. Toma un CPE detectado y busca (sin explotar) CVEs asociados en NVD.
6. Ajusta `--version-intensity` de 0 a 9 sobre el mismo host y compara resultados y ruido.

Reto verificable

Genera un inventario de servicios de un host de laboratorio con producto, versión y CPE, y añade una columna "riesgo potencial" citando al menos un CVE público asociado a una de las versiones detectadas (solo referencia, sin explotación). Entrega la salida `-oA` y la tabla.

Criterio de aceptación: las versiones y CPE coinciden con un reescaneo del revisor, y el CVE citado corresponde realmente a la versión reportada según NVD.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>-O</code> no identifica el OS	Falta un puerto cerrado o el host filtra; usa <code>--osscan-guess</code> o abre el alcance de puertos
Versión aparece como "tcpwrapped"	El servicio cierra la conexión tras el handshake; suele indicar filtrado o control de acceso
<code>-sV</code> muy lento	Intensidad alta o muchos puertos; baja intensidad o limita con <code>-p</code>
CPE ausente	Nmap no reconoció el producto; sube intensidad o revisa manualmente el banner
OS reportado con baja fiabilidad	Pila TCP/IP atípica (NAT, dispositivos embebidos); toma el resultado como conjetura

Preguntas frecuentes

 ¿`-sV` explota el servicio? No. Solo envía sondas benignas y compara banners/respuestas. No intenta comprometer nada.

 ¿Puedo confiar al 100% en la versión detectada? No siempre. Los banners pueden estar ofuscados o modificados. Trátalo como una hipótesis fuerte, verificable con más pruebas.

 ¿Por qué el OS a veces sale como varias opciones? Cuando ninguna huella supera el umbral de fiabilidad, Nmap lista las candidatas más probables. Dispositivos tras NAT o embebidos complican la identificación.

 ¿Qué gano con el CPE? Es la llave para automatizar la búsqueda de vulnerabilidades: se cruza con bases como NVD para saber qué CVEs afectan a esa versión concreta.

Referencias

- Lyon, G. *Nmap Network Scanning*, cap. "Service and Application Version Detection" y "OS Detection". <https://nmap.org/book/vscan.html>
- Nmap OS Detection. <https://nmap.org/book/osdetect.html>
- CPE Dictionary (NIST). <https://nvd.nist.gov/products/cpe>
- NVD — National Vulnerability Database. <https://nvd.nist.gov/>

Siguiente clase

Clase 032 - Nmap Scripting Engine (NSE)